

Hospital Management System
Secure Design Principles and Threat Modeling
Ruqaya Abdulhussein

- Receptionist – Registers new patients and assigns doctors.
- Nurse – Views and updates patient records.
- Doctor – Views and updates patient records, prescribes medication.

b. Identify the main processes and data stores

Main Processes:

- Authentication & Authorization (User login, OTP verification).
- Change Password (allows users to change their password).
- User Management (Account creation, role assignment, access control).
- Patient Registration (Recording personal information).
- Appointments Management (Scheduling, assigning doctors).
- Patient Record Management (Viewing and updating medical records and Doctors prescribing medication) .
- Email/OTP Services (Sending verification codes via email).

Main Data Stores:

- Hospital Management Database - Stores all tables related to the system
- Users Table – Stores login credentials, user information, and roles.
- Patient Table – Stores personal information
- Medical Records Table - Stores diagnosis and prescriptions issued by doctors.
- Appointment Table – Stores scheduled appointments.
- Email Communication Table - Stores email credentials for OTP sending.

Identify the trust level of each user

- Admin – High trust (Full access to user accounts, needs strict authentication).
- Receptionist – Medium trust (Can register patients and assign doctors but has no access to medical records).
- Nurse – Medium-high trust (Can view and update patient records but cannot prescribe medication).
- Doctor – High trust (Can access, update patient records, and prescribe medications).

d. Identify any external dependencies

- Database Server – Stores patient records, user data, and appointments.
- Email Service (JavaMail) – Sends OTPs for authentication.

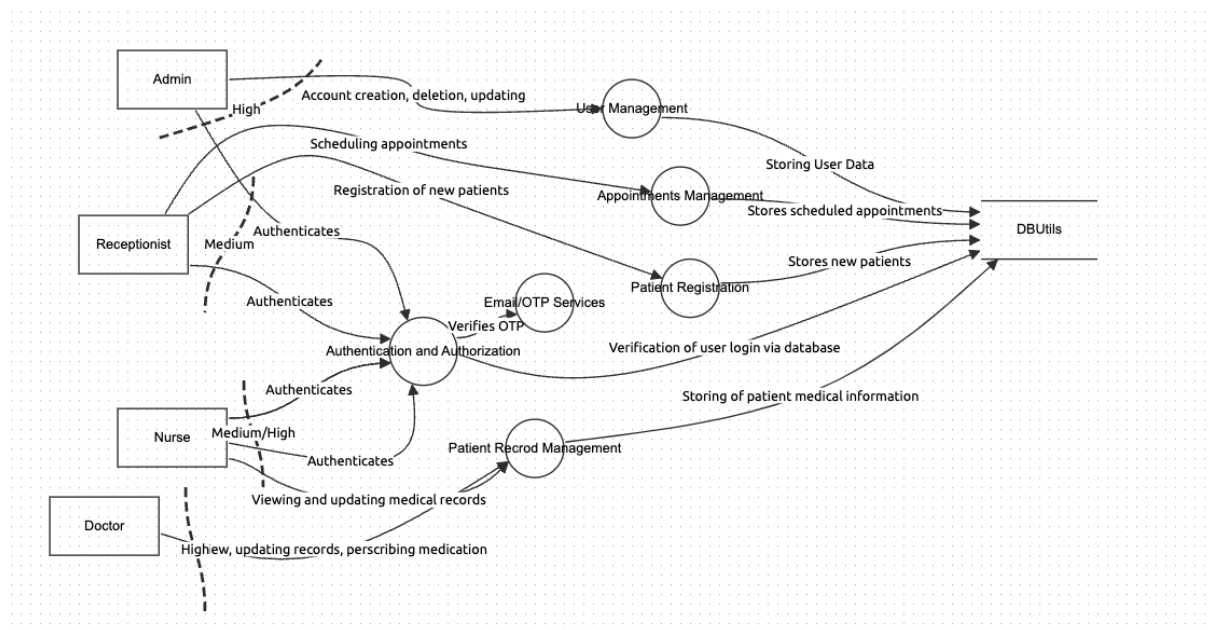
e. Identify the entry/exit points and map them to user trust levels

- Login Page – Used by all users for authentication.
- Change Password Page - Used by all users to change their password.

- Admin Panel – Used by admins to manage user accounts.
- Patient Registration – Used by receptionists to register new patients.
- Appointment Management – Used by receptionists to schedule appointments.
- Patient Records – Used by nurses and doctors to access patient data.
- Medical Records – Used by nurses and doctors to add diagnosis given as well as for doctors to prescribe treatment.
- OTP Email Service – Used for authentication.
- Database Access – System backend handling sensitive data.

f. Identify the Assets

- User Credentials – Login details, hashed passwords, OTPs.
- Patient Records – Personal information.
- Appointment Data – Scheduled patient visits.
- Medical Records Data – Diagnosis and medication history.
- Database – Central storage of all sensitive data.



Threat Description	Impersonation - An attacker could impersonate a Doctor, Nurse, or Admin by using stolen credentials.
Threat Target	User accounts, authentication system.
Risk	7.8
Attack Techniques	Phishing, credential stuffing, brute-force attacks

Countermeasures	Implement MFA, secure password hashing, rate-limit login attempts
-----------------	---

Threat Description	Records Modification - A malicious actor (or insider threat) could alter patient records, prescriptions, or user data.
Threat Target	Patient records, prescriptions
Risk	7.2
Attack Techniques	SQL Injection, insider threats
Countermeasures	Use RBAC, implement access logs.

Threat Description	Repudiation - A doctor (or attacker) could deny modifying a patient's record or prescription.
Threat Target	Audit logs
Risk	5.8
Attack Techniques	Log deletion, false claims
Countermeasures	Enforce strict access policies

Threat Description	Data Leakage - Unauthorized access to sensitive patient records and prescriptions
Threat Target	Patient records
Risk	7.8
Attack Techniques	Insider threats, weak access controls
Countermeasures	Hash/Encrypt data. Monitoring, and role-based access restrictions

Threat Description	Disrupting availability (DoS) - An attacker could overload the system (e.g., brute-force login attempts, spam patient registrations).
Threat Target	Login system, database

Risk	8.2
Attack Techniques	Brute-force login, spam registrations, DDoS
Countermeasures	Enable rate limiting

Threat Description	Gaining unauthorized access - A compromised Receptionist or Nurse account could gain Doctor/Admin privileges.
Threat Target	Role-based access control (RBAC), authentication
Risk	7.8
Attack Techniques	Exploiting misconfigured privileges, privilege escalation attacks
Countermeasures	Implement MFA and least privilege principle